

UNIVERSIDAD PRIVADA DOMINGO SAVIO

Facultad de Ingeniería en Sistemas

Ingeniería en Sistemas

Asignatura: Tecnologías Web

Grupo 7

PROYECTO

Sistema de Tutorías y Modalidades de Grado

Seguridad del Sistema

Análisis de amenazas y controles

Integrantes Edilzon Jorge Katty Quispe
Yamil Nieves Trujillo
Sergio Estrada S.
Ximena Calcina B.

Docente Jose Jonathan Cardozo Romay

Fecha 28/09/2026

Control del documento

Institucion	UNIVERSIDAD PRIVADA DOMINGO SAVIO
Facultad	Facultad de Ingenieria en Sistemas
Proyecto	Sistema de Tutorias y Modalidades de Grado (Grupo 7)
Asignatura	Tecnologias Web
Documento	Seguridad del Sistema
Tipo	Analisis de amenazas y controles
Version	1.0
Docente	Jose Jonathan Cardozo Romay
Integrantes	Edilzon Jorge Katty Quispe; Yamil Nieves Trujillo; Sergio Estrada S.; Ximena Calcina B.
Fecha de entrega	28/09/2026

Indice

1. Introducción	5
2. Modelo de amenazas	6
2.1 Superficie de ataque.....	6
2.2 Amenazas identificadas.....	8
3. Autenticación	8
3.1 Almacenamiento de contraseñas.....	8
3.2 Flujo de autenticación	9
3.3 Control de intentos fallidos	11
4. Control de sesiones	11
5. Protección contra CSRF	12
6. Protección contra XSS	13
7. Consultas preparadas y control de inyección	14
8. Autorización y control de acceso	15
8.1 Matriz de permisos.....	15
8.2 Permisos por rol	15
8.3 Restricciones adicionales	16
9. Validación de entrada	17
9.1 Esquemas de validación	17
9.2 Reglas disponibles	17
9.3 Principio de confianza	17
10. Carga de archivos	19
11. Auditoría y trazabilidad	20
11.1 Registro de accesos	20
11.2 Trazabilidad del proceso de grado	20
11.3 Principios de auditoría.....	20

12. Seguridad de la base de datos.....	22
13. Seguridad de la configuración	23
14. Mapa de controles por capa	24
15. Plan de contingencias.....	26
16. Resumen de controles.....	27

Análisis de Seguridad Versión: 1.0

1. Introducción

Este documento describe las medidas de seguridad implementadas en el Sistema de Tutorías y Modalidades de Grado. La seguridad es un requisito transversal que atraviesa todas las capas de la aplicación, desde la recepción de la petición HTTP hasta la entrega de la respuesta al cliente.

Los objetivos de seguridad del sistema son:

- **Confidencialidad** — proteger la información sensible de los estudiantes, docentes y del proceso académico.
 - **Integridad** — garantizar que la información no sea alterada de forma indebida.
 - **Disponibilidad** — asegurar que el sistema esté accesible para sus usuarios legítimos.
 - **Autenticación y autorización** — garantizar que cada usuario acceda únicamente a las operaciones que le corresponden.
-

2. Modelo de amenazas

2.1 Superficie de ataque

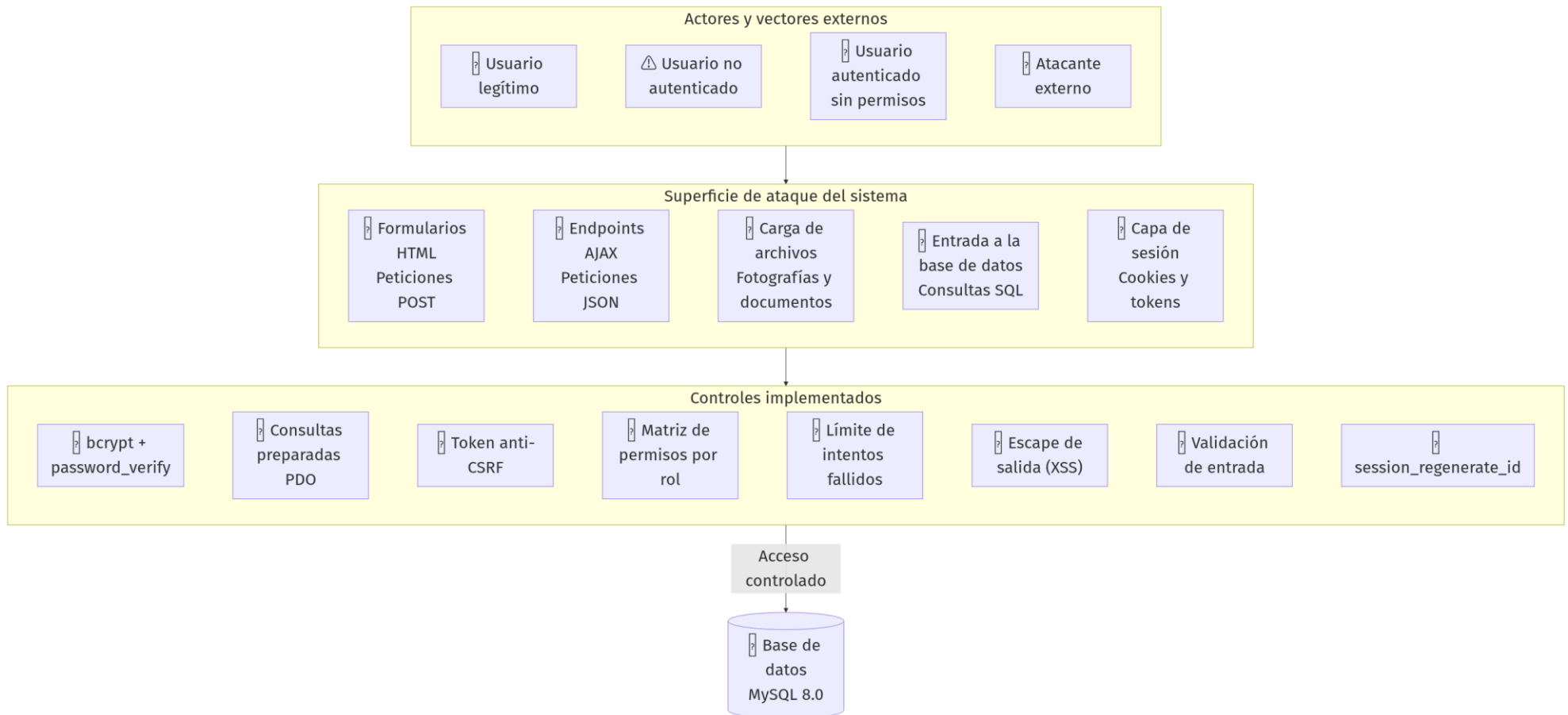


Figura 1. 2.1 Superficie de ataque

2.2 Amenazas identificadas

#	Amenaza	Descripción	Vector	Control aplicado
A-01	Inyección SQL	Inserción de código malicioso en las consultas.	Formularios y AJAX	Consultas preparadas PDO parametrizadas.
A-02	Cross-Site Scripting (XSS)	Inyección de scripts en las páginas generadas.	Salida de datos	<code>htmlspecialchars()</code> en todas las vistas.
A-03	Cross-Site Request Forgery (CSRF)	Suplantación de la identidad del usuario mediante peticiones falsificadas.	Formularios	Token por sesión con <code>hash_equals()</code> .
A-04	Roba de credenciales	Obtención de contraseñas por fuerza bruta o filtraciones.	Formulario de acceso	bcrypt, limitación de intentos y auditoría.
A-05	Acceso no autorizado	Un usuario accede a funciones de otro rol.	Peticiones HTTP directas	Matriz de permisos y guardas de sesión.
A-06	Escalada de privilegios	Un usuario modifica su propio rol o estado.	Peticiones manipuladas	Permisos de escritura negados por rol.
A-07	Subida de archivos maliciosos	Carga de archivos con extensión o contenido peligroso.	Carga de documentos	Validación de tipo, tamaño y nombre generado.
A-08	Fijación de sesión	Reutilización del identificador de sesión por un atacante.	Manipulación de cookies	<code>session_regenerate_id(true)</code> tras autenticar.
A-09	Exposición de información	Revelación de datos por mensajes de error.	Formulario de acceso	Mensajes genéricos de credenciales.
A-10	Denegación de servicio	Agotamiento de recursos por peticiones masivas.	Peticiones repetidas	Límite de intentos, paginación y consultas optimizadas.

3. Autenticación

3.1 Almacenamiento de contraseñas

Las contraseñas **nunca se almacenan en texto plano**. El sistema utiliza el algoritmo **bcrypt**, provisto por PHP mediante `password_hash()` con la constante `PASSWORD_DEFAULT`.

```
// Registro de usuario
$hash = password_hash($password, PASSWORD_DEFAULT);

// Verificación en el inicio de sesión
if (password_verify($password, $usuario['password_hash'])) {
    // Credenciales correctas
}
```

Características de bcrypt aplicadas

Propiedad	Valor	Efecto
Algoritmo	bcrypt	Resistente a ataques con hardware especializado.
Costo	Configurado por PHP (por defecto 10)	Incrementa el tiempo de cómputo por hash.
Sal	Generada automáticamente por <code>password_hash()</code>	Dos contraseñas idénticas producen hashes distintos.
Verificación	<code>password_verify()</code> en tiempo constante	Evita comparaciones vulnerables a temporización.

3.2 Flujo de autenticación

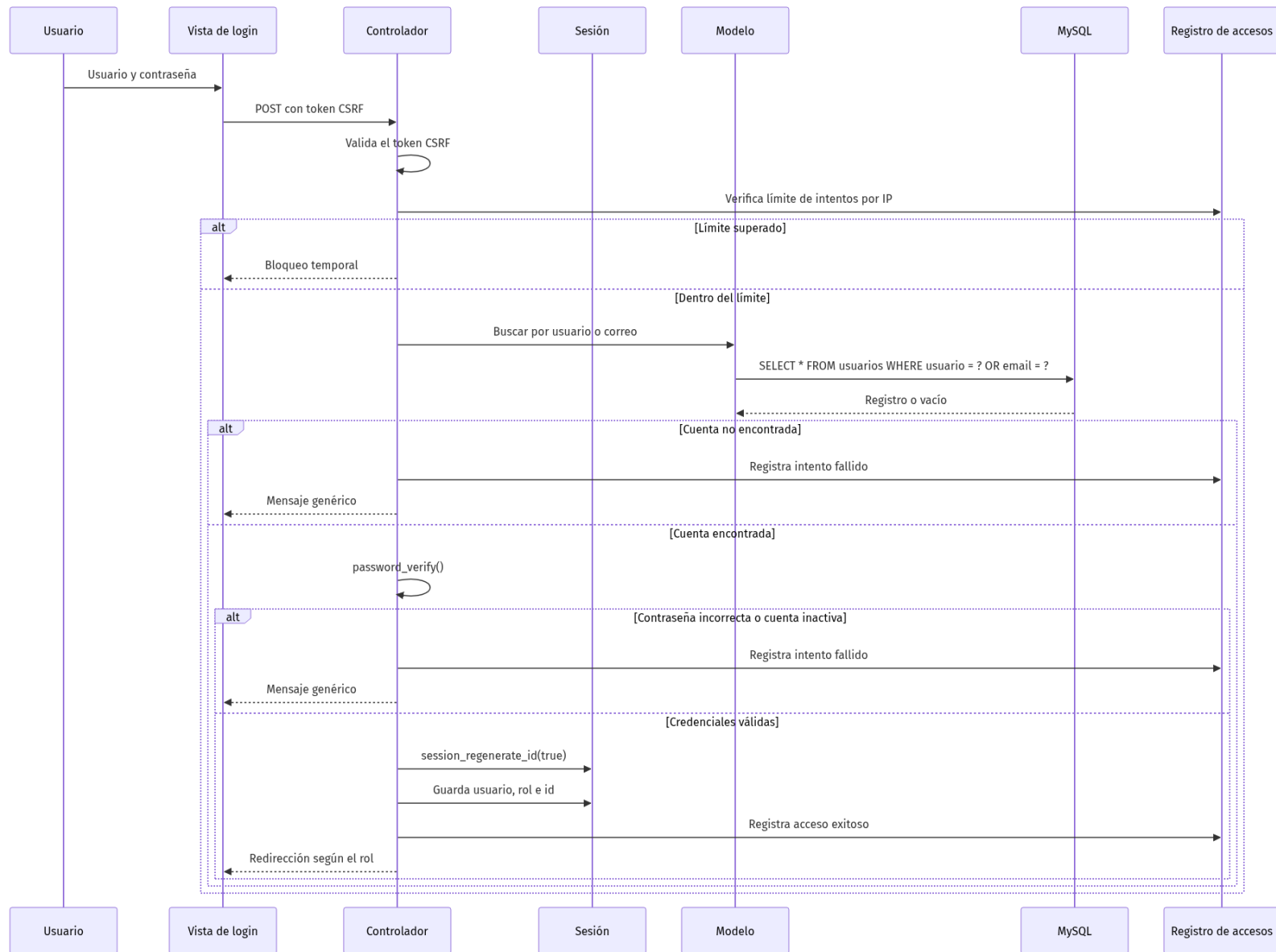


Figura 2. 3.2 Flujo de autenticación

3.3 Control de intentos fallidos

Atributo	Valor
Límite	10 intentos fallidos
Ventana de tiempo	15 minutos
Unidad de control	Dirección IP de origen
Persistencia	Tabla <code>registro_accesos</code>

Este mecanismo dificulta los ataques de fuerza bruta, ya que el atacante debe rotar direcciones IP para superar el umbral, lo que eleva significativamente el costo del ataque.

4. Control de sesiones

Medida	Implementación	Propósito
Cookie HttpOnly	Configuración de <code>session.cookie_httponly</code>	Impide que JavaScript acceda al identificador de sesión.
Cookie Secure	Activada en entorno HTTPS	Evita el envío del identificador en texto plano.
Cookie SameSite	Configuración <code>Lax</code> o <code>Strict</code>	Reduce el riesgo de CSRF y de fugas de sesión.
Renovación del identificador	<code>session_regenerate_id(true)</code> tras autenticar	Evita la fijación de sesión.
Guarda de autenticación	Verificación en cada punto de entrada	Impide el acceso a áreas protegidas sin sesión.
Destrucción de sesión	<code>session_destroy()</code> + expiración de cookies	Garantiza el cierre efectivo de la sesión.
Timeout de inactividad	Controlado por la configuración de PHP	Limita la ventana de exposición de una sesión abierta.

5. Protección contra CSRF

Todas las operaciones que modifican información (crear, actualizar, eliminar) exigen un **token anti-CSRF** válido, almacenado en la sesión y enviado como campo oculto del formulario.

```
// Generación del token
$_SESSION['csrf_token'] = bin2hex(random_bytes(32));

// Validación
function verificarCsrf() {
    $tokenSesion = $_SESSION['csrf_token'];
    $tokenFormulario = $_POST['csrf_token'];
    return hash_equals($tokenSesion, $tokenFormulario);
}
```

Propiedades aplicadas

Propiedad	Detalle
Generación criptográfica	<code>random_bytes(32)</code> produce 32 bytes aleatorios seguros.
Representación	hexadecimal de 64 caracteres.
Comparación	<code>hash_equals()</code> realiza la comparación en tiempo constante.
Cobertura	Formularios HTML y peticiones AJAX.
Método	Solo las operaciones POST aceptan escritura de datos.

6. Protección contra XSS

Toda salida dinámica se escapa antes de incluirse en el HTML.

```
// Función de escape utilizada en las vistas
function return htmlspecialchars($valor) {
    return e($valor) ?? '', ENT_QUOTES, 'UTF-8');
}
```

Vector	Tratamiento
XSS almacenado	Los datos se escapan en el momento de renderizarlos, no al guardarlos.
XSS reflejado	Los parámetros recibidos se escapan antes de mostrarlos.
Atributos HTML	ENT_QUOTES escapa comillas simples y dobles.
Codificación	UTF-8 explícito para evitar interpretación incorrecta de caracteres.
JSON	Las respuestas AJAX se transmiten con json_encode() y se consumen sin interpolación directa en HTML.

7. Consultas preparadas y control de inyección

Toda consulta SQL se ejecuta mediante **PDO con parámetros vinculados**, nunca por concatenación de cadenas.

```
//                                Consulta                                segura
$sql = "SELECT * FROM tutorias WHERE tutor_id = ? AND estado = ?";
$stmt = $db->prepare($sql);
$stmt->execute([$tutorId, $estado]);
$resultados = $stmt->fetchAll(PDO::FETCH_ASSOC);

//                                Consulta                                insegura                                -                                nunca                                debe                                usarse
$sql = "SELECT * FROM tutorias WHERE tutor_id = " . $tutorId;
```

Aspecto	Implementación
API de acceso	PDO en modo <code>ERRMODE_EXCEPTION</code> .
Parámetros	Marcadores <code>?</code> con array de valores, o parámetros con nombre.
Orden de resultados	Nombres de columna explícitos; no se usa <code>SELECT *</code> en las consultas críticas.
Transacciones	Operaciones compuestas se envuelven en <code>beginTransaction()</code> / <code>commit()</code> .

8. Autorización y control de acceso

8.1 Matriz de permisos

El sistema implementa una matriz de permisos declarada en `includes/permisos.php`. Cada operación declara el permiso requerido y el sistema lo verifica antes de ejecutar la acción.

```
// Verificación de un permiso
function tienePermiso($permiso, $rol = null) {
    $rol = $rol ?? ($_SESSION['rol'] ?? null);
    return isset(PERMISOS[$rol]) && in_array($permiso, PERMISOS[$rol], true);
}
```

8.2 Permisos por rol

Permiso	Administrador	Tutor	Estudiante	Coordinador MG	Auxiliar MG
ver_dashboard	✓	—	—	—	—
gestionar_usuarios	✓	—	—	—	—
gestionar_carreras	✓	—	—	—	—
gestionar_materias	✓	—	—	—	—
crear_oferta	✓	—	—	—	—
ver_tutorias	✓	✓	✓	—	—
gestionar_disponibilidad	✓	✓	—	—	—
solicitar_tutoria	✓	—	✓	—	—
cambiar_estado_tutoria	✓	✓	Solo cancelar	—	—
evaluar_tutoria	—	—	✓	—	—
gestionar_modalidades	✓	—	—	✓	—
declarar_modalidad	✓	—	✓	—	—
gestionar_avales	✓	—	—	✓	✓
revisar_declaraciones	✓	—	—	✓	✓
aprobar_declaraciones	✓	—	—	✓	—
importar_padron_mg	✓	—	—	✓	✓
asignar_tutor_mg	✓	—	—	✓	—
registrar_etapas	✓	—	—	✓	✓
asignar_jurado	✓	—	—	✓	✓
registrar_actas	✓	—	—	✓	✓
generar_documentos	✓	—	—	✓	✓

Permiso	Administrador	Tutor	Estudiante	Coordinador MG	Auxiliar MG
gestionar_parametros_mg	✓	—	—	✓	—
ver_reportes_mg	✓	—	—	✓	✓

8.3 Restricciones adicionales

Regla	Descripción
Propiedad de los datos	El tutor solo accede a las tutorías donde figura como tutor asignado.
Restricción por alcance	El estudiante solo accede a sus propias solicitudes y evaluaciones.
Operaciones críticas por POST	Las acciones que modifican datos exigen el método POST.
Rol no modificable	El usuario no puede alterar su propio rol ni su estado de cuenta.
Denegación por defecto	Todo permiso no declarado explícitamente se deniega.

9. Validación de entrada

La validación se aplica en dos niveles: en el **servidor** (obligatorio) y en el **navegador** (complementaria).

9.1 Esquemas de validación

```
$esquema = [
    'titulo_proyecto' => [
        'requerido' => true,
        'min' => 10,
        'max' => 200,
    ],
    'resumen' => [
        'requerido' => true,
        'max' => 2000,
    ],
    'periodo_id' => [
        'requerido' => true,
        'entero' => true,
        'existe' => 'mg_periodos',
    ],
];
```

9.2 Reglas disponibles

Regla	Función	Ejemplo de uso
requerido	El campo no puede estar vacío.	Título del proyecto
min / max	Longitud mínima y máxima.	Observaciones (máx. 1000)
email	Formato de correo válido.	Correo institucional
entero	Valor numérico entero.	Semestre del estudiante
en	Pertenencia a un conjunto de valores.	Estado de la tutoría
existe	El registro debe existir en la tabla indicada.	Identificador de periodo
unico	El valor no debe estar registrado previamente.	Correo del usuario

9.3 Principio de confianza

Regla	Aplicación
El cliente no es confiable	Ninguna validación del navegador sustituye la del servidor.
Validación en el servidor	Toda entrada se procesa únicamente después de validarse en PHP.
Normalización	Los datos se almacenan en el formato canónico definido por el dominio.

10. Carga de archivos

Medida	Descripción
Validación de extensión	Solo se aceptan las extensiones previstas para cada tipo de carga.
Validación de tamaño	Se impone un límite máximo al tamaño del archivo.
Nombre generado	El archivo se almacena con un nombre generado por el servidor.
Nombre original preservado	El nombre recibido se guarda únicamente como metadato escapado.
Directorio no ejecutable	La carpeta de carga no permite la ejecución de scripts.
Registro de trazabilidad	Se asocia la ruta del archivo con el registro que lo originó.

11. Auditoría y trazabilidad

11.1 Registro de accesos

Atributo	Contenido
usuario_id	Identificador del usuario cuando la cuenta existe.
usuario_intento	Valor enviado en el formulario de acceso.
ip_address	Dirección de origen de la petición.
user_agent	Navegador y sistema operativo del cliente.
exito	Resultado del intento.
fecha_intento	Momento exacto del intento.

Esta tabla permite reconstruir la actividad de acceso y detectar patrones anómalos, como ataques de fuerza bruta o intentos de enumeración de cuentas.

11.2 Trazabilidad del proceso de grado

Elemento	Registro
Asignación de tutor	Historial completo con estado, motivo de finalización y carta asociada.
Etapas del expediente	Fechas de inicio y cierre, resultado y responsable del registro.
Actas de defensa	Número, fecha, nota final, resultado, firmas y fecha de sella.
Documentos emitidos	Correlativo, contenido íntegro como instantánea, fecha y responsable.
Importaciones	Detalle por fila con el resultado de cada registro procesado.

11.3 Principios de auditoría

Principio	Aplicación
Inmutabilidad	Los registros históricos no se eliminan; se marcan con un estado final.
Trazabilidad temporal	Toda acción sensible registra fecha y responsable.
Integridad referencial	ON DELETE RESTRICT impide borrar registros con historial asociado.
Separación de los datos de auditoría	Los datos de auditoría se conservan aunque cambie el dato original.

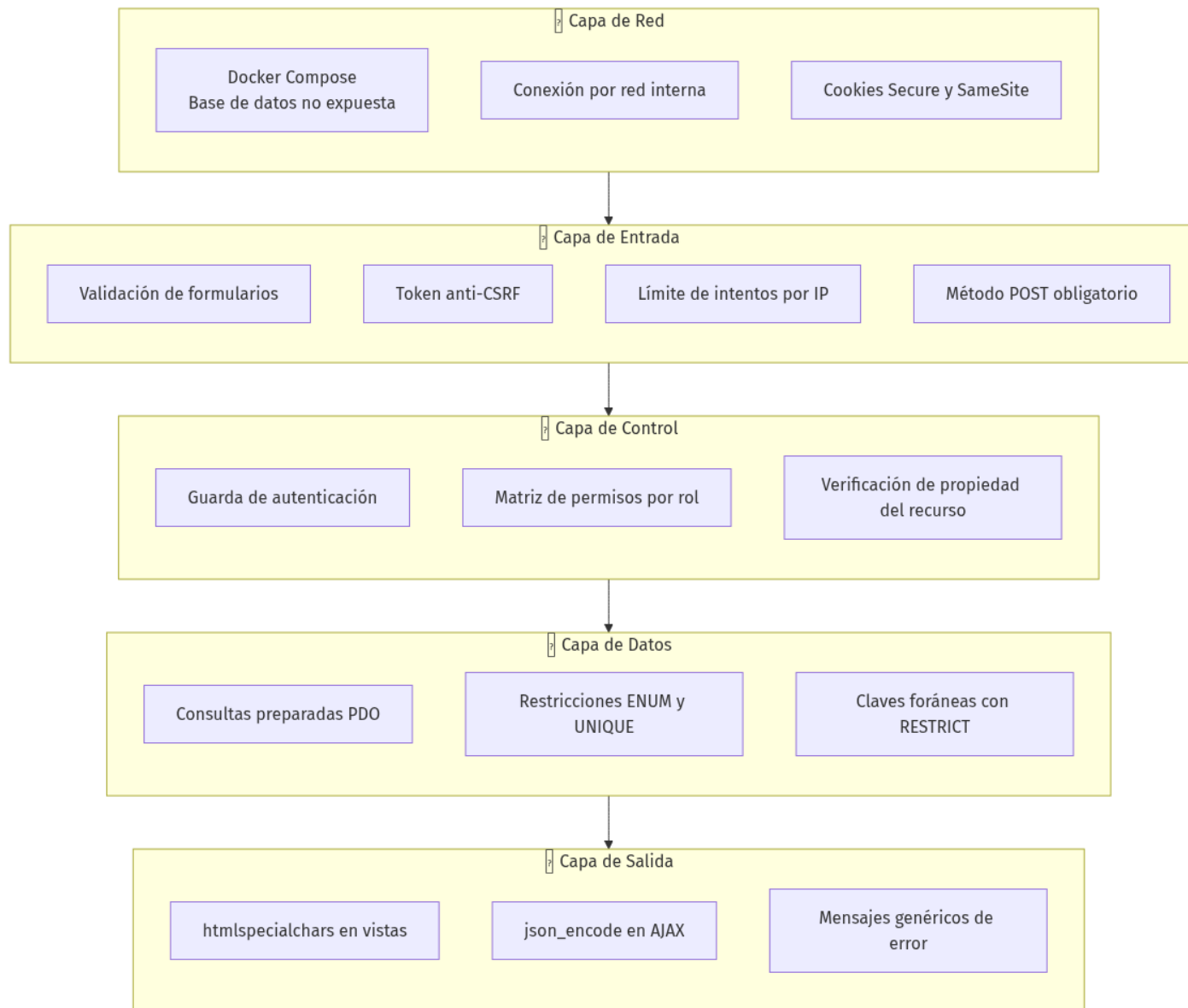
12. Seguridad de la base de datos

Medida	Descripción
Usuario dedicado	La aplicación se conecta con un usuario con privilegios limitados al esquema del sistema.
Acceso por red interna	El servidor de base de datos no se expone al exterior; solo es accesible desde la red de contenedores.
Variables de entorno	Las credenciales se configuran fuera del código fuente.
Motor InnoDB	Garantiza transacciones y integridad referencial.
Restricciones de dominio	Los campos ENUM impiden estados no contemplados en el modelo.
Restricciones `UNIQUE`	Impiden la duplicación de claves de negocio.
Codificación `utf8mb4`	Evita problemas de almacenamiento de caracteres especiales.

13. Seguridad de la configuración

Medida	Descripción
Archivo sensible fuera del document root	<code>config/</code> y <code>database/</code> residen fuera de <code>public/</code> .
Punto de entrada único	El front controller impide el acceso directo a archivos internos del proyecto.
Modo de depuración controlado	El detalle de los errores solo se muestra con <code>APP_DEBUG</code> activo.
Credenciales por entorno	<code>.env</code> no se versiona en el repositorio.
Protección de la base	La carpeta <code>database/</code> no es accesible por HTTP.

14. Mapa de controles por capa

*Figura 3. 14. Mapa de controles por capa*

15. Plan de contingencias

Escenario	Respuesta del sistema
Intento de acceso masivo	El límite por IP bloquea el origen durante 15 minutos; los intentos quedan registrados.
Token CSRF ausente o inválido	La operación se rechaza con el mensaje "La solicitud expiró"; no se modifica ningún dato.
Acceso a recurso ajeno	El sistema deniega la operación e informa la falta de permisos, sin revelar datos del recurso.
Transición de estado inválida	La operación se rechaza indicando los estados involucrados en la solicitud.
Archivo con extensión no permitida	La carga se rechaza antes de almacenar el archivo.
Fallo de la conexión de base de datos	La capa de conexión reintenta y, si persiste, muestra un mensaje de indisponibilidad controlado.

16. Resumen de controles

#	Control	Tipo	Estado
1	Hash bcrypt de contraseñas	Autenticación	Implementado
2	Verificación con <code>password_verify()</code>	Autenticación	Implementado
3	Mensajes genéricos de credenciales	Confidencialidad	Implementado
4	Límite de 10 intentos por IP / 15 min	Anti-fuerza bruta	Implementado
5	Regeneración del identificador de sesión	Anti-fijación de sesión	Implementado
6	Cookies HttpOnly, Secure y SameSite	Sesión	Implementado
7	Token anti-CSRF con <code>random_bytes()</code>	Integridad	Implementado
8	Verificación con <code>hash_equals()</code>	Integridad	Implementado
9	Consultas preparadas PDO al 100%	Inyección SQL	Implementado
10	Escape con <code>htmlspecialchars()</code>	XSS	Implementado
11	Validación declarativa en servidor	Integridad	Implementado
12	Matriz de permisos por rol	Autorización	Implementado
13	Verificación de propiedad del recurso	Autorización	Implementado
14	Restricción de operaciones a POST	Integridad	Implementado
15	Validación y renombrado de archivos	Carga de archivos	Implementado
16	Registro de accesos con IP y fecha	Auditoría	Implementado
17	Claves foráneas con <code>RESTRICT</code>	Integridad referencial	Implementado
18	Restricciones <code>ENUM</code> y <code>UNIQUE</code>	Integridad de dominio	Implementado
19	Base de datos no expuesta a Internet	Aislamiento de red	Implementado
20	Credenciales fuera del código fuente	Configuración	Implementado
21	Front controller único	Exposición de archivos	Implementado
22	Historial inmutable de asignaciones	Trazabilidad	Implementado

#	Control	Tipo	Estado
23	Instantánea de documentos emitidos	Trazabilidad	Implementado
24	Modo de depuración controlado	Manejo de errores	Implementado

Fin del documento de Seguridad